

Brute Force - Multiple User Login Failures Detected on Same Machine

MITRE ATTACK :		T1097.004	T1056	T1033	T1110
L1 Note :	I checked the authentication logs and saw same users login failures, but I could not understand if the brute force attack was successful or not				
Username :	Stephen				
Source Address :	89.187.185.171				
Destination Address :	172.16.17.153				
Alert Trigger Reason :	More than 8 different login fail attempts were detected within 5 minutes.				

Para um bruteforce é simples, verificar o eventID que indica sucesso no login, nesse caso se for achado um eventID 4624, já que é um sistema WINDOWS, que pode ser verificado no EDR.

OBS: Caso fosse um sistema Linux o modo seria ir em /var/logs/auth.log e procurar por “Accepted Password”

Host Information					
Hostname:	Stephen		Domain:	LetsDefend	
IP Address:	172.16.17.153		Bit Level:	64-bit	
OS:	Windows 10		Primary User:	LetsDefend	
Client/Server:	Client		Last Login:	2023-12-26 05:12:00	

Primeiro é possível observar que o ataque veio de fora da rede, é bom verificar a reputação desse IP

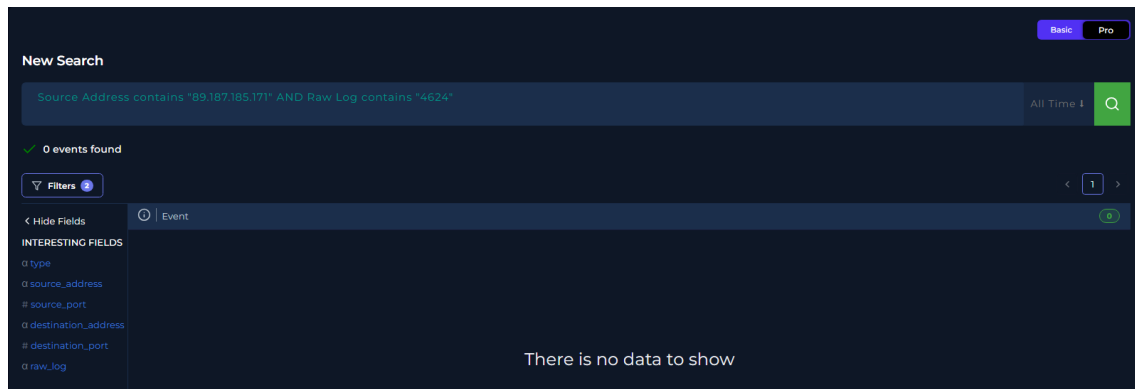
The screenshot displays the AbuseIPDB website interface. At the top, there's a search bar with the IP 89.187.185.171 entered. Below the search bar, a summary card shows a 'Caution' level (10% Abuse Confidence Score) and a '2/91' security vendors flagged this IP address as malicious. The main content area is divided into tabs: DETECTION, DETAILS, RELATIONS, and COMMUNITY. The DETAILS tab is active, showing a table of security vendors' analysis. The table lists vendors like Chong Lua Dao, alphaMountain.ai, and GreyNoise, along with their analysis results (Malicious, Suspicious). A sidebar on the left contains a 'feedback' button and a list of reports for the IP. The bottom of the page features a 'Log in to view charts and search reports for this IP.' button and a 'HIDE CHARTS' button.

A análise indica leve suspeita de IP malicioso, parece estar relacionado com ataques BOT e bruteforce.

Agora é bom ver se ele tentou o ataque em outros hosts



Aparentemente o ataque foi direcionado na porta RDP de apenas um host



Filtrando o log é possível observar que ele não obteve sucesso

IoCs:

Endereços IP:

- **89.187.185.171**

Vetor de Ataque:

Uma porta RDP exposta para a Internet, tentativa de ataque bruteforce contra o usuário Stephen no host 172.16.17.153

Análise:

Um serviço RDP exposto parece ter sido detectado por um BOT de acordo com o que o AbuseIPDB forneceu, tentou se conectar na conta através de um bruteforce e falhou.

Recomendações:

- Não deixar o serviço RDP exposto para a Internet a não ser que seja realmente necessário

- Mudar o texto de resposta do RDP, “the user is correct, but the password is wrong” facilita o trabalho de um atacante na hora da enumeração, priorize mensagens mais genéricas como “User or Password incorrect”
- Bloquear o IP malicioso